



Lecture 4

Business Continuity Planning
and Disaster Recovery Planning

Planning for Business Continuity

- Business continuity planning (BCP) involves assessing the risks to organizational processes and creating policies, plans, and procedures to minimize the impact those risks might have on the organization if they were to occur.
- BCP is used to maintain the continuous operation of a business in the event of an emergency. The goal of BCP planners is to implement a combination of policies, procedures, and processes such that a potentially disruptive event has as little impact on the business as possible.
- BCP focuses on maintaining business operations with reduced or restricted infrastructure capabilities or resources.
- As long as the continuity of the organization's ability to perform its mission-critical work tasks is maintained, BCP can be used to manage and restore the environment.
- The overall goal of BCP is to provide a quick, calm, and efficient response in the event of an emergency and to enhance a company's ability to recover from a disruptive event promptly.

Project Scope and Planning

- As with any formalized business process, the development of a resilient business continuity plan requires the use of a proven methodology.
- Organizations should approach the planning process with several goals in mind:
 - Perform a structured review of the business's organization from a crisis planning point of view.
 - Create a BCP team with the approval of senior management.
 - Assess the resources available to participate in business continuity activities.
 - Analyze the legal and regulatory landscape that governs an organization's response to a catastrophic event.

Organizational Review

- One of the first responsibilities of the individuals responsible for business continuity planning is to perform an analysis of the business organization to identify all departments and individuals who have a stake in the BCP process. Here are some areas to consider:
 - Operational departments that are responsible for the core services the business provides to its clients
 - Critical support services, such as the IT department, facilities and maintenance personnel, and other groups responsible for the upkeep of systems that support the operational departments
 - Corporate security teams responsible for physical security, since they are many times the first responders to an incident and are also responsible for the physical safeguarding of the primary facility and alternate processing facility
 - Senior executives and other key individuals essential for the ongoing viability of the organization
- This identification process is critical for two reasons:
 - First, it provides the groundwork necessary to help identify potential members of the BCP team.
 - Second, it builds the foundation for the remainder of the BCP process.

BCP Team Selection

- In some organizations, the IT and/or security departments bear sole responsibility for business continuity planning, and no other operational or support departments provide input.
- Those departments may not even know of the plan's existence until a disaster looms on the horizon or actually strikes the organization.
- This is a critical flaw!
- The isolated development of a business continuity plan can spell disaster in two ways.
 - First, the plan itself may not take into account knowledge possessed only by the individuals responsible for the day-to-day operation of the business.
 - Second, it keeps operational elements "in the dark" about plan specifics until implementation becomes necessary.

BCP Team Selection

- The team should include, at a minimum, the following individuals:
 - Representatives from each of the organization's departments responsible for the core services performed by the business
 - Business unit team members from the functional areas identified by the organizational analysis
 - IT subject-matter experts with technical expertise in areas covered by the BCP
 - Cybersecurity team members with knowledge of the BCP process
 - Physical security and facility management teams responsible for the physical plant
 - Attorneys familiar with corporate legal, regulatory, and contractual responsibilities
 - Human resources team members who can address staffing issues and the impact on individual employees
 - Public relations team members who need to conduct similar planning for how they will communicate with stakeholders and the public in the event of a disruption
 - Senior management representatives with the ability to set the vision, define priorities, and allocate resources

Resource Requirements

- After the team validates the organizational review, it should turn to an assessment of the resources required by the BCP effort.
- This assessment involves the resources needed by three distinct BCP phases:
 - BCP Development - The BCP team will require some resources to perform the four elements of the BCP process (project scope and planning, business impact analysis, continuity planning, and approval and implementation).
 - BCP Testing, Training, and Maintenance - The testing, training, and maintenance phases of BCP will require some hardware and software commitments.
 - BCP Implementation - When a disaster strikes and the BCP team deems it necessary to conduct a full-scale implementation of the business continuity plan, the implementation will require significant resources.

Business Impact Analysis

- Once your BCP team completes the four stages of preparing to create a business continuity plan, it's time to dive into the heart of the work—the business impact analysis (BIA).
- The BIA identifies the business processes and tasks that are critical to an organization's ongoing viability and the threats posed to those resources.
- It also assesses the likelihood that each threat will occur and the impact those occurrences will have on the business.
- The results of the BIA provide you with quantitative measures that can help you prioritize the commitment of business continuity resources to the various local, regional, and global risk exposures facing your organization.

Business Impact Analysis

- There are two different types of analyses that business planners use when facing a decision:
 - Quantitative Impact Assessment - Involves the use of numbers and formulas to reach a decision. This type of data often expresses options in terms of the dollar value to the business.
 - Qualitative Impact Assessment - Takes non-numerical factors, such as reputation, investor/customer confidence, workforce stability, and other concerns, into account. This type of data often results in categories of prioritization (such as high, medium, and low).

Identifying Priorities

- The first BIA task facing the BCP team is identifying business priorities.
- Depending on your line of business, certain activities are essential to your day-to-day operations when disaster strikes.
- You should create a comprehensive list of critical business functions and rank them in order of importance.
- These critical business functions will vary from organization to organization, based on each organization's mission.
- They are the activities that, if disrupted, would jeopardize the organization's ability to achieve its goals.

Identifying Priorities

- To begin the quantitative assessment, the BCP team should sit down and draw up a list of organization assets and then assign an asset value (AV) in monetary terms to each asset.
- The second quantitative measure that the team must develop is the maximum tolerable downtime (MTD), sometimes also known as maximum tolerable outage (MTO). The MTD is the maximum length of time a business function can tolerate a disruption before suffering irreparable harm.
- The recovery time objective (RTO) for each business function is the amount of time in which you think you can feasibly recover the function in the event of a disruption. As you conduct your BCP work, ensure that your RTOs are less than your MTDs, resulting in a situation in which a function should never be unavailable beyond the maximum tolerable downtime.
- While the RTO and MTD measure the time to recover operations and the impact of that recovery time on operations, organizations must also pay attention to the potential data loss that might occur during an availability incident.
- The recovery point objective (RPO) is the data loss equivalent to the time-focused RTO. The RPO defines the point in time before the incident where the organization should be able to recover data from a critical business process.

Risk Identification

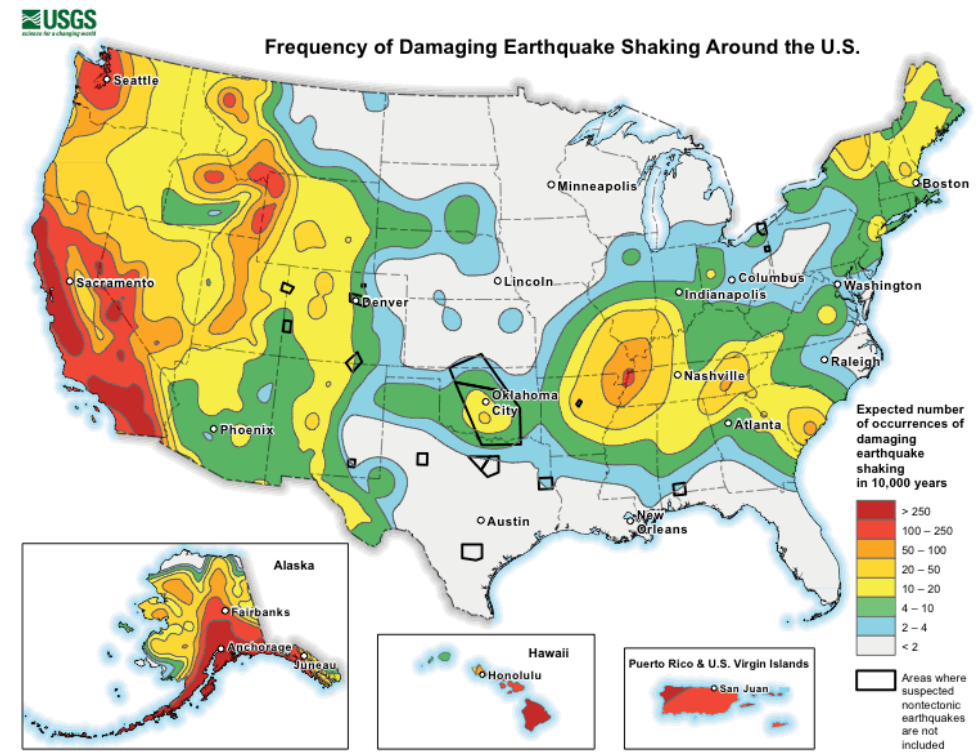
- The next phase of the BIA is the identification of risks posed to your organization.
- Risks come in two forms: natural risks and person-made risks.
- The following list includes some events that pose natural threats:
 - Violent storms/hurricanes/tornadoes/blizzards
 - Lightning strikes
 - Earthquakes
 - Mudslides/avalanches
 - Volcanic eruptions
 - Pandemics

Risk Identification

- Person-made threats include the following events:
 - Terrorist acts/wars/civil unrest
 - Theft/vandalism
 - Fires/explosions
 - Prolonged power outages
 - Building collapses
 - Transportation failures
 - Internet disruptions
 - Service provider outages
 - Economic crises

Likelihood Assessment

- The preceding step consisted of the BCP team's drawing up a comprehensive list of the events that can be a threat to an organization.
- You probably recognized that some events are much more likely to happen than others.
- To account for these differences, the next phase of the business impact analysis identifies the likelihood that each risk will occur.
- We describe this likelihood using the same process used for the risk assessment in Lecture 4.
- In many cases, you may be able to find likelihood assessments for some risks prepared by experts at no cost to you. For example, the U.S. Geological Survey (USGS) developed the earthquake hazard map.



Impact Analysis

- In this phase, you analyze the data gathered during risk identification and likelihood assessment and attempt to determine what impact each one of the identified risks would have on the business if it were to occur.
- From a quantitative point of view, we will cover three specific metrics: the exposure factor, the single loss expectancy, and the annualized loss expectancy.
 - The exposure factor (EF) is the amount of damage that the risk poses to the asset, expressed as a percentage of the asset's value.
 - The single loss expectancy (SLE) is the monetary loss expected each time the risk materializes.
 - The annualized loss expectancy (ALE) is the monetary loss that the business expects to suffer as a result of the risk harming the asset during a typical year.

Continuity Planning

- Continuity planning focuses on developing and implementing a continuity strategy to minimize the impact realized risks might have on protected assets.
- The strategy development phase bridges the gap between the business impact analysis and the continuity planning phases of BCP development.
 - The BCP team must now take the prioritized list of concerns raised by the quantitative and qualitative resource prioritization exercises and determine which risks will be addressed by the business continuity plan.
- In the provisions and processes phase, the BCP team designs the specific procedures and mechanisms that will mitigate the risks deemed unacceptable during the strategy development stage.
 - Three categories of assets must be protected through BCP provisions and processes: people, buildings/facilities, and infrastructure.

Disaster Recovery Planning

- Disaster recovery planning brings order to the chaos that surrounds the interruption of an organization's normal activities. By its very nature, a disaster recovery plan is designed to cover situations where tensions are already high and cooler heads may not naturally prevail.
- Picture the circumstances in which you might find it necessary to implement DRP measures—a hurricane destroys your main operations facility; a fire devastates your main processing center; terrorist activity closes off access to a major metropolitan area. Any event that stops, prevents, or interrupts an organization's ability to perform its work tasks (or threatens to do so) is considered a disaster.
- The moment that IT becomes unable to support mission-critical processes is the moment DRP kicks in to manage the restoration and recovery procedures.
- A disaster recovery plan should be set up so that it can almost run on autopilot. The DRP should also be designed to reduce decision making activities during a disaster as much as possible.
- Essential personnel should be well trained in their duties and responsibilities in the wake of a disaster and also know the steps they need to take to get the organization up and running as soon as possible.

Understand System Resilience, High Availability, and Fault Tolerance

- Technical controls that add to system resilience and fault tolerance directly affect availability, one of the core goals of the CIA Triad (confidentiality, integrity, and availability).
- A primary goal of system resilience and fault tolerance is to eliminate single points of failure in critical business systems.
- A single point of failure (SPOF) is any component that can cause an entire system to fail.
 - If a computer has data on a single disk, failure of the disk can cause the computer to fail, so the disk is a single point of failure.
 - If a database-dependent website includes multiple web servers all served by a single database server, the database server is a single point of failure.

Understand System Resilience, High Availability, and Fault Tolerance

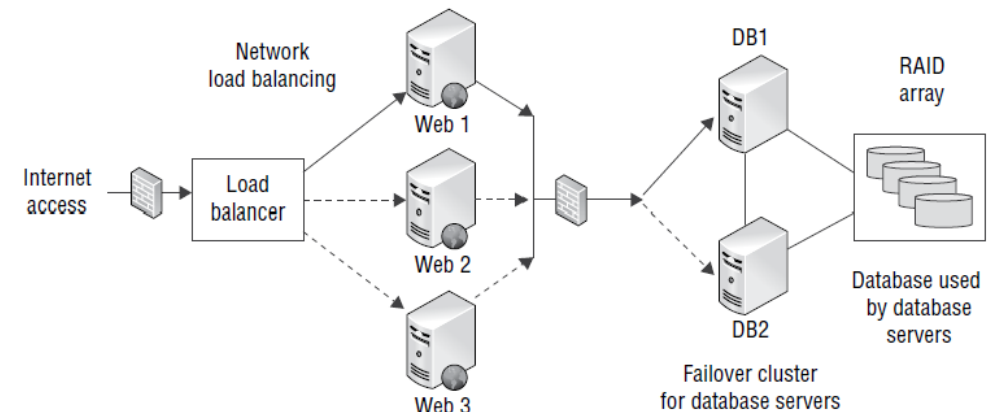
- System resilience refers to the ability of a system to maintain an acceptable level of service during an adverse event.
 - This could be a hardware fault managed by fault-tolerant components, or it could be an attack managed by other controls such as effective intrusion prevention systems.
 - In some contexts, it refers to the ability of a system to return to a previous state after an adverse event.
 - For example, if a primary server in a failover cluster fails, fault tolerance ensures that the system fails over to another server.
 - System resilience implies that the cluster can fail back to the original server after the original server is repaired.

Understand System Resilience, High Availability, and Fault Tolerance

- Fault tolerance is the ability of a system to suffer a fault but continue to operate.
 - Fault tolerance is achieved by adding redundant components, such as additional disks within a properly configured RAID array or additional servers within a failover clustered configuration.
- High availability is the use of redundant technology components to allow a system to quickly recover from a failure after experiencing a brief disruption.
 - High availability is often achieved through the use of load balancing and failover servers.

Protecting Servers

- Fault tolerance can be added for critical servers with failover clusters.
- A failover cluster includes two or more servers, and if one of the servers fails, another server in the cluster can take over its load in an automatic process called failover.
- Failover clusters can include multiple servers (not just two), and they can also provide fault tolerance for multiple services or applications.



Trusted Recovery

- Trusted recovery provides assurances that after a failure or crash, the system is just as secure as it was before the failure or crash occurred.
- Depending on the failure, the recovery may be automated or require manual intervention by an administrator.
- However, in either case systems can be designed to ensure that they support trusted recovery.
- Systems can be designed so that they fail in a fail-secure state or a fail-open state.
 - A fail-secure system will default to a secure state in the event of a failure, blocking all access.
 - A fail-open system will fail in an open state, granting all access. The choice is dependent on whether security or availability is more important after a failure.

Quality of Service

- Quality of service (QoS) controls protect the availability of data networks under load.
- Many different factors contribute to the quality of the end-user experience, and QoS attempts to manage all of those factors to create an experience that meets business requirements.
- Some of the factors contributing to QoS are as follows:
 - Bandwidth - The network capacity available to carry communications.
 - Latency - The time it takes a packet to travel from source to destination.
 - Jitter - The variation in latency between different packets.
 - Packet Loss - Some packets may be lost between source and destination, requiring retransmission.
 - Interference - Electrical noise, faulty equipment, and other factors may corrupt the contents of packets.

Alternate Processing Sites

- One of the most important elements of the disaster recovery plan is the selection of alternate processing sites to be used when the primary sites are unavailable.
- Many options are available when considering recovery facilities, limited only by the creative minds of disaster recovery planners and available resources.
- In the following sections, we cover several types of sites commonly used in disaster recovery planning: cold sites, warm sites, hot sites, mobile sites, and cloud computing.

Alternate Processing Sites

- One of the most important elements of the disaster recovery plan is the selection of alternate processing sites to be used when the primary sites are unavailable.
- Many options are available when considering recovery facilities, limited only by the creative minds of disaster recovery planners and available resources.
- In the following sections, we cover several types of sites commonly used in disaster recovery planning: cold sites, warm sites, hot sites, mobile sites, and cloud computing.

Cold sites

- Cold sites are standby facilities large enough to handle the processing load of an organization and equipped with appropriate electrical and environmental support systems.
- They may be large warehouses, empty office buildings, or other similar structures.
- However, a cold site has no computing facilities (hardware or software) preinstalled and also has no active broadband communications links.
- The major advantage of a cold site is its relatively low cost—there's no computing base to maintain and no monthly telecommunications bill when the site is idle.
- However, the drawbacks of such a site are obvious—there is a tremendous lag between the time the decision is made to activate the site and the time when that site is ready to support business operations.
 - Servers and workstations must be brought in and configured.
 - Data must be restored from backup tapes.
 - Communications links must be activated or established.
 - The time to activate a cold site is often measured in weeks, making a quick recovery close to impossible.

Hot Sites

- A hot site is the exact opposite of the cold site. In this configuration, a backup facility is maintained in constant working order, with a full complement of servers, workstations, and communications links ready to assume primary operations responsibilities.
- The servers and workstations are all preconfigured and loaded with appropriate operating system and application software.
- The data on the primary site servers is periodically or continuously replicated to corresponding servers at the hot site, ensuring that the hot site has up-to-date data.
- The advantages of a hot site are obvious—the level of disaster recovery protection provided by this type of site is unsurpassed.
- However, the cost is extremely high. Maintaining a hot site essentially doubles an organization's budget for hardware, software, and services and requires the use of additional employees to maintain the site.

Warm Sites

- Warm sites occupy the middle ground between hot and cold sites for disaster recovery specialists.
- They always contain the equipment and data circuits necessary to rapidly establish operations.
- As with hot sites, this equipment is usually preconfigured and ready to run appropriate applications to support an organization's operations.
- Unlike hot sites, however, warm sites do not typically contain copies of the client's data.
- The main requirement in bringing a warm site to full operational status is the transportation of appropriate backup media to the site and restoration of critical data on the standby servers.
- Activation of a warm site typically takes at least 12 hours from the time a disaster is declared.

Mobile Sites

- Mobile sites are non-mainstream alternatives to traditional recovery sites.
- They typically consist of self-contained trailers or other easily relocated units.
- These sites include all the environmental control systems necessary to maintain a safe computing environment.
- Mobile sites are usually configured as cold sites or warm sites, depending on the disaster recovery plan they are designed to support.

Cloud Computing

- Many organizations now turn to cloud computing as their preferred disaster recovery option.
- Infrastructure-as-a-service (IaaS) providers, such as Amazon Web Services (AWS), Microsoft Azure, and Google Compute Engine, offer on-demand service at low cost.
- Companies wishing to maintain their own datacenters may choose to use these IaaS options as backup service providers.
- Storing ready-to-run images with cloud providers is often quite cost effective and allows the organization to avoid incurring most of the operating cost until the cloud site activates in a disaster.

Mutual Assistance Agreements

- Mutual assistance agreements (MAAs), also called reciprocal agreements, are popular in disaster recovery literature but are rarely implemented in real-world practice.
- In theory, they provide an excellent alternate processing option.
- Under an MAA, two organizations pledge to assist each other in the event of a disaster by sharing computing facilities or other technological resources.
- MAAs are difficult to enforce. The parties might trust each other to provide support in the event of a disaster. However, when push comes to shove, the nonvictim might renege on the agreement.
- Cooperating organizations should be located in relatively close proximity to each other to facilitate transportation of employees between sites. However, proximity means that both organizations may be vulnerable to the same threats.
- Confidentiality concerns often prevent businesses from placing their data in the hands of others. These may be legal concerns (such as in the handling of healthcare or financial data) or business concerns (such as trade secrets or other intellectual property issues).